

PUBLIC - EDUCATIONAL USE ONLY

SIMULATED THIRD-PARTY SUPPLY CHAIN AUDIT REPORT

ISO/IEC 27001:2022 Information Security
Management System Assessment

Target Organisation: Sigstore Project (Cosign, Rekor & Fulcio)
A Linux Foundation / OpenSSF Initiative

Report Date	July, 2026
Report Reference	SA-SIGSTORE-2026-001
Lead Auditor	Fuzail Khan, ISO/IEC 27001:2022 Lead Auditor
Training Provider	Mastermind - Simulated Audit (Educational Purposes Only)
Document Version	v1.0 - Final
Audit Standard	ISO/IEC 27001:2022 with Annex A 2022 Controls
Scope Summary	Cosign, Rekor, Fulcio - Engineering Governance, Cryptographic Infrastructure & SDLC
Classification	PUBLIC - Open-Source Simulation / Portfolio Project

⚠ FORMAL DISCLAIMER

This report is a simulated, educational audit conducted entirely via publicly available open-source information. It does not represent a formal ISO/IEC 27001:2022 certification audit, does not constitute legal or regulatory advice, and does not imply any official assessment of, or endorsement by, the Sigstore project, the Linux Foundation, or any accredited certification body. No confidential or proprietary information was accessed or used in the preparation of this report. This document has been produced solely for professional portfolio and educational purposes.

Prepared by: Mr. Fuzail Khan Personal Portfolio Project Document v1.0 - Final

Summary - For Non-Technical Readers

The full technical findings, evidence base, and formal audit conclusions begin on the following page.

What is Sigstore and why does it matter?

Every time you download a software application, install a library, or pull a container image, you are trusting that the software has not been tampered with since the developer created it. Sigstore is a free, publicly available service - used by companies including Google, GitHub, and Red Hat - that allows software developers to cryptographically sign their work. Think of it as a global, tamper-proof notary service for software. When a developer releases code through Sigstore, a permanent, unfalsifiable record is created proving who signed it, when, and from where. This matters because software supply chain attacks - where malicious code is inserted into trusted software packages before they reach end users - are among the fastest-growing categories of cybersecurity threat globally.

What is this audit?

This document is a simulated ISO/IEC 27001:2022 information security audit of the Sigstore project, conducted entirely using publicly available information for educational and professional portfolio purposes. ISO 27001 is the internationally recognised standard for information security management - the same standard that banks, hospitals, and government agencies use to certify that their security practices meet a rigorous, independently verified benchmark. This audit applies that same framework to Sigstore's governance structure, cryptographic infrastructure, and secure development practices.

What did the audit find?

The audit identified no critical security failures. All ten of the most important security controls governing Sigstore's core cryptographic infrastructure - the systems that issue digital certificates, maintain the transparency log, and protect the root of trust - were found to be fully implemented and effective.

Six minor administrative gaps were identified. None of these represent a technical security failure. They represent areas where formal documentation or governance processes have not yet been established to the level required by the standard - for example, the absence of a formal disaster recovery plan with documented recovery time targets, and the absence of a structured internal audit programme. These are common findings even in mature organisations transitioning to ISO 27001 certification.

Nine additional observations were noted as opportunities for improvement. The most technically interesting of these is an unresolved tension between European data protection law (GDPR) and a core architectural design decision: once a user's email address is recorded in Sigstore's transparency log as part of a signing event, it cannot be deleted - because deleting it would break the cryptographic integrity of the log that makes the whole system trustworthy. This is a genuine, publicly acknowledged trade-off with no perfect resolution.

What is the overall conclusion?

Based on this simulated assessment, the recommendation is Certify with Conditions - meaning the project demonstrates a sufficiently strong security posture to merit certification under ISO 27001:2022, subject to the six minor administrative gaps being formally remediated within 90 days. The project's core security architecture is sound, its cryptographic infrastructure is correctly implemented, and its open-source governance model - while unconventional by corporate standards - provides effective oversight of the systems that millions of software consumers rely on daily.

© Fuzail Khan | LA-27001 | Simulated Report

Document Control

Version	Date	Author	Change Description	Status
0.1	February 2026	Mr. Fuzail Khan	Initial draft - Phase 1: Context, Scope & Asset Register	Draft
0.2	March 2026	Mr. Fuzail Khan	Phase 2: Risk Register & Statement of Applicability	Draft
0.3	April 2026	Mr. Fuzail Khan	Phase 3 & 4: Support, Operations & Performance Evaluation	Draft
0.4	May 2026	Mr. Fuzail Khan	Phase 5: Stage 2 Evidence Verification (Annex A)	Draft
1.0	July 2026	Mr. Fuzail Khan	Phase 6: NCRs, CAPA & Certification Recommendation - Final	Final

Table of Contents

Document Control	4
1. Executive Summary	7
2. Audit Objectives, Criteria & Methodology	8
2.1 Audit Objectives.....	8
2.2 Audit Criteria.....	8
2.3 Audit Methodology.....	8
2.4 Audit Limitations & Evidence Caveats	8
3. Context, Scope & Asset Register (Clauses 4–5)	10
3.1 Organisational Context (Clause 4.1).....	10
Top Management Designation (Clause 5.1)	10
Security Response Committee (SRC).....	10
3.2 Interested Parties (Clause 4.2)	10
3.3 ISMS Scope Statement (Clause 4.3)	11
Scope Boundary Summary	11
3.4 Information Asset Register	12
4. Risk Register & Statement of Applicability (Clause 6)	13
4.1 Risk Assessment Methodology (Clause 6.1.2).....	13
4.2 Technical Risk Register	17
4.3 Risk Treatment Plan (Clause 6.1.3).....	19
4.4 Statement of Applicability (Clause 6.1.3d)	21
5. Support & Operational Planning (Clauses 7 & 8).....	22
5.1 Resources & Competence (Clauses 7.1 & 7.2).....	22
5.2 Awareness & Communication (Clauses 7.3 & 7.4).....	22
5.3 Documented Information (Clause 7.5)	22
5.4 Operational Planning & Control (Clause 8.1)	23
5.5 Risk Treatment Implementation (Clause 8.3).....	23
6. Performance Evaluation (Clause 9).....	24
6.1 Monitoring, Measurement & Evaluation (Clause 9.1)	24
6.2 Internal Audit Evidence (Clause 9.2).....	24
6.3 Management Review (Clause 9.3).....	24
7. Stage 2 Evidence Verification (Annex A Controls).....	25
7.1 Organisational Controls (A.5.1 – A.5.37)	25
7.2 People Controls (A.6.1 – A.6.8)	26
7.3 Physical Controls (A.7.1 – A.7.14)	26

7.4 Technological Controls (A.8.1 – A.8.34)	27
8. NCRs, CAPA & Certification Recommendation (Clause 10).....	29
8.1 Non-Conformity Classification.....	29
8.2 Non-Conformity Reports	30
8.3 CAPA Plan	38
8.4 Formal Certification Recommendation	40
Appendix A - Statement of Applicability (ISO/IEC 27001:2022 - All 93 Controls).....	41
Appendix B - Evidence Index & Artifact References	63

1. Executive Summary

Recommendation	Major NCRs	Minor NCRs	Observations
Certify with Conditions	0	6	9

Zero Major NCRs confirmed - all ten critical cryptographic infrastructure controls verified as fully implemented and effective.

This simulated desk review of the Sigstore project's Information Security Management System identified zero Major non-conformities and confirmed that all ten critical risk-register controls governing the project's core cryptographic trust infrastructure are fully implemented and effective. Six Minor NCRs were raised against administrative and process controls, primarily reflecting the inherent friction of applying traditional ISO 27001 requirements to a distributed, open-source governance model rather than systemic failures of security architecture. Nine Observations were identified representing opportunities to strengthen documentation governance, formalise existing informal practices, and address an unresolved architectural tension between GDPR erasure obligations and the cryptographic immutability of the Rekor transparency log.

2. Audit Objectives, Criteria & Methodology

2.1 Audit Objectives

The objectives of this simulated third-party supply chain audit are to:

- Evaluate the design adequacy of Sigstore's ISMS against the requirements of ISO/IEC 27001:2022.
- Assess the operational effectiveness of applicable Annex A controls within the defined scope.
- Identify and document non-conformities, observations, and opportunities for improvement.
- Produce a formal certification recommendation based on the accumulated evidence.

2.2 Audit Criteria

The primary audit criterion is ISO/IEC 27001:2022, including all requirements of Clauses 4 through 10 and applicable Annex A controls. Supporting reference standards include:

- NIST SP 800-218 (Secure Software Development Framework - SSDF)
- OpenSSF Best Practices Badge Criteria
- CNCF Software Supply Chain Best Practices
- SLSA (Supply-chain Levels for Software Artifacts) Framework

2.3 Audit Methodology

This audit was conducted as a two-stage desk review using exclusively publicly available information. All evidence was drawn from the Sigstore project's public GitHub repositories, official project documentation, the Sigstore Technical Charter (adopted under LF Projects Series Agreement), and the project website (sigstore.dev). No access to private systems, personnel interviews, or confidential documentation was available or attempted.

Stage 1 involved a review of ISMS documentation, governance structures, and scope definition (Clauses 4–6). Stage 2 involved evidence verification of operational controls against applicable Annex A requirements (Clauses 7–10 and Appendix A).

2.4 Audit Limitations & Evidence Caveats

This audit was conducted exclusively via publicly available information, which imposes several inherent limitations on the depth and certainty of findings. First, the audit team had no ability to request documentation, conduct personnel interviews, or observe operational processes directly - all findings are therefore based on what is explicitly documented in public repositories and official project communications rather than on verified operational practice. Second, several controls assessed as Implemented or Partially Implemented in the Statement of Applicability rely on infrastructure configurations that are referenced in public architecture documentation but are not directly inspectable without privileged access to the GCP environment - most notably A.8.11 (Data Masking), where API-level parameter filtering is referenced but unconfirmed via direct configuration review. Third, the currency of evidence cannot be fully guaranteed - public documentation may not reflect the most recent operational state of the project, and controls confirmed as implemented at the time of this review may have changed subsequent to the evidence collection date. Fourth, the audit team was unable to verify the internal deliberations of the TSC or SRC, the content of private

security advisory communications, or the specific identity and rotation status of current TUF keyholders beyond what is publicly disclosed in the root-signing repository. These limitations are inherent to the simulated desk review methodology and do not invalidate the findings documented in this report, but they do underscore the requirement for a formal Stage 2 audit with direct auditee access before any binding certification decision could be made in a real-world context.

© Fuzail Khan | LA-27001 | Simulated Report

3. Context, Scope & Asset Register (Clauses 4–5)

3.1 Organisational Context (Clause 4.1)

Sigstore is an open-source project operating under the Linux Foundation (LF Projects, LLC) and the Open Source Security Foundation (OpenSSF). It provides free, public-good cryptographic signing and transparency infrastructure for the software supply chain. The project is not a commercial entity and has no traditional organisational hierarchy; it operates through a contributor governance model defined in its Technical Charter.

The project's mission, as stated in Charter Section 1.a, is to empower software maintainers to easily sign software artifacts and store those artifacts into a production-grade public transparency log.

Top Management Designation (Clause 5.1)

For the purposes of this ISMS assessment, top management is formally designated as the Technical Steering Committee (TSC) acting as a collective body, which holds the ultimate authority and responsibility for all technical oversight of the project pursuant to Charter Sections 2.a and 2.g(vi). The TSC is authorised to establish security issue reporting policies (Charter Sec. 2.g.vi) and makes binding decisions by majority vote with a quorum of 50% of voting members (Charter Sec. 3.b-3.c).

Name	Organisation	TSC Role	Email
Santiago Torres-Arias	Purdue University	TSC Chair	santiagotorres@purdue.edu
Bob Callaway	Google	TSC Member	bcallaway@google.com
Luke Hinds	Stacklok	TSC Member	luke@stacklok.com
Priya Wadhwa	Chainguard	TSC Member	priya@chainguard.dev
Trevor Rosen	GitHub	TSC Member	trevrosen@github.com

Security Response Committee (SRC)

Sigstore maintains a dedicated Security Response Committee (SRC) responsible for coordinating vulnerability disclosure and incident response across all in-scope components. The SRC operates with 3–5 members maintained on a vendor-diverse basis. New members are nominated by existing SRC members or project maintainers, selected based on codebase expertise. Contact: security@sigstore.dev.

3.2 Interested Parties (Clause 4.2)

The following table identifies the interested parties whose needs and expectations are relevant to the Sigstore ISMS, together with the applicable regulatory or standards driver for each requirement.

Interested Party	Requirement from Sigstore	Applicable Standard / Regulation
Downstream Financial Entities (Banks, Insurers, Trading Venues)	Cryptographically verifiable build provenance and tamper-evident transparency logs to prevent unauthorised software production deployments.	Digital Operational Resilience Act (DORA) - ICT Risk Management & Supply Chain Pillars

Commercial Software Vendors (EU Market Distributors)	Immutable digital signatures and machine-readable attestations to certify product integrity and a secure development lifecycle.	EU Cyber Resilience Act (CRA) - Essential Cybersecurity Requirements for Products with Digital Elements
US Federal Agencies & Government Contractors	Cryptographically signed software artifacts and non-falsifiable provenance documentation to satisfy federal procurement criteria.	US Executive Order 14028 - Improving the Nation's Cybersecurity / NIST SP 800-218 SSDF Compliance
Kubernetes / CNCF Ecosystem Consumers (Kyverno, OPA Gatekeeper)	High availability and low-latency verification from the public-good infrastructure (Rekor, Fulcio) to enforce cluster admission policies without blocking valid deployments.	CNCF Software Supply Chain Best Practices - Cloud Native Operational Resilience
Package Registries & CI/CD Platforms (npm, GitHub Actions)	High throughput and cryptographic integrity of the transparency log to automatically generate and verify build attestations linked to source repositories.	SLSA (Supply-chain Levels for Software Artifacts) - Non-falsifiable Provenance Framework
LF Projects LLC & OpenSSF (Governance & Parent Bodies)	Adherence to transparent governance structures, maintenance of security standards, and protection of trademark and domain assets.	Sigstore Project Charter (Section 5) & OpenSSF Best Practices Badge Criteria

3.3 ISMS Scope Statement (Clause 4.3)

The scope of the Information Security Management System (ISMS) for the Sigstore project, governed by the Technical Steering Committee (TSC), encompasses the engineering governance, secure development lifecycle, and cryptographic infrastructure of its core components (Cosign, Rekor, Fulcio) and their live public-good production instances. The boundary explicitly includes the TUF root-signing infrastructure, as it houses the foundational cryptographic trust anchor essential to ecosystem integrity. Conversely, the Kubernetes Policy Controller and language SDKs are explicitly excluded, as they operate strictly as downstream API consumers rather than authoritative generators of trust material. Physical corporate security is also excluded due to the project's completely distributed, open-source nature. Finally, the ISMS interfaces with, but does not control, critical external dependencies, specifically relying on GitHub for repository hosting and pipeline execution, third-party OpenID Connect (OIDC) providers for user identity authentication, and Google Cloud Platform (GCP) for the hosting and operation of the live public-good production infrastructure.

Scope Boundary Summary

Dimension	Detail
In Scope - Systems	Cosign (codebase & CLI), Rekor (transparency log service), Fulcio (certificate authority), TUF Root-Signing Infrastructure (sigstore/root-signing), Timestamp Authority (TSA), Sigstore Public-Good Production Infrastructure (rekor.sigstore.dev, fulcio.sigstore.dev)
In Scope - Functions	Engineering governance (documented TSC policies and procedural outputs), cryptographic infrastructure design and operations, secure development lifecycle including CI/CD pipeline security, artifact signing workflows, and vulnerability management.

Explicitly Excluded	Corporate HR & physical office security (no corporate premises); external OIDC identity providers (Google, GitHub, Microsoft); language SDKs (sigstore-go, sigstore-python, sigstore-java - API consumers that do not host cryptographic trust material); Kubernetes Policy Controller (excluded - downstream API consumer, not an authoritative generator of trust material)
External Interfaces	GitHub (source code hosting & CI/CD execution platform); third-party OIDC providers (identity authentication dependency for Fulcio certificate issuance); Google Cloud Platform (GCP) - confirmed hosting provider for rekor.sigstore.dev and fulcio.sigstore.dev (EV-008).

3.4 Information Asset Register

The following information assets have been identified within the defined ISMS scope. Asset owners are designated by role rather than individual name to reflect the open-source governance model. CIA ratings reflect Confidentiality / Integrity / Availability sensitivity assessments (H = High, M = Medium, L = Low).

Asset ID	Asset Name	Category	Asset Owner	Conf.	Integ.	Avail.
AST-001	Cosign Codebase & CLI	Primary - Software Asset	Cosign Maintainers	M	H	H
AST-002	Fulcio (Certificate Authority)	Primary - Cryptographic Service	TSC / SRC	H	H	H
AST-003	Rekor (Transparency Log)	Primary - Audit Log Service	TSC / SRC	L	H	H
AST-004	TUF Root-Signing Infrastructure	Primary - Trust Anchor	TSC / Keyholders	H	H	H
AST-005	Timestamp Authority (TSA)	Primary - Cryptographic Service	TSC	M	H	H
AST-006	Sigstore Public Infrastructure	Primary - Production Service	TSC / Infra Team	L	H	H
AST-007	Policy Controller	Excluded	N/A	-	-	-
AST-008	GitHub CI/CD Workflow Pipelines	Supporting - Process Asset	Repo Maintainers	M	H	M
AST-009	SECURITY.md & Vulnerability Disclosure Process	Supporting - Documentation	SRC	L	H	L
AST-010	Governance Documentation (Charter, CONTRIBUTING)	Supporting - Documentation	TSC	L	M	L

Note: Ephemeral key pairs and OIDC identity tokens were evaluated as candidate assets and determined to be transient process inputs rather than discrete information assets. Their associated risks are addressed via controls A.8.24 (Cryptography) and A.5.17 (Authentication Information) respectively.

4. Risk Register & Statement of Applicability (Clause 6)

4.1 Risk Assessment Methodology (Clause 6.1.2)

4.1.1 Methodology Overview

Risks are assessed using a quantitative 5×5 matrix in which a Risk Score is calculated as Likelihood × Impact, producing a score on a scale of 1 to 25. All scores are calibrated specifically to the Sigstore ecosystem's role as a public-good cryptographic trust anchor, rather than using generic enterprise definitions.

4.1.2 Likelihood Scale

Level	Rating	Frequency Threshold	Sigstore-Specific Context
Rare	1	Less than once every 5 years	Theoretical attack on established cryptographic primitives (e.g., SHA-256 collision), or simultaneous compromise of multiple offline TUF keyholders' hardware tokens requiring coordinated multi-party collusion.
Unlikely	2	Once every 2 to 5 years	Highly sophisticated, targeted zero-day exploits against Sigstore's core components or breaches of heavily audited upstream software dependencies (e.g., the Go standard cryptography library).
Possible	3	Once every 6 to 24 months	Deployment pipeline misconfigurations, minor operational procedural lapses, or targeted social engineering attacks against individual (non-root) core maintainers.
Likely	4	Once or twice per quarter	Localised infrastructure downtime of rekor.sigstore.dev, short-term service degradation under heavy CI/CD load, or minor edge-case software bugs causing client verification failures.
Almost Certain	5	Multiple times per month, or continuously during high-volume global release periods	Automated vulnerability scanner alerts on secondary Go or Node.js dependencies, routine rate-limiting events triggered by global CI/CD spikes, or third-party CVE publications against non-critical transitive dependencies.

4.1.3 Impact Scale

Level	Rating	Sigstore Ecosystem Impact
Insignificant	1	A brief latency spike in Rekor log ingestion that does not violate published SLOs; a cosmetic bug in Cosign CLI output that does not affect cryptographic verification integrity.
Minor	2	Transient downtime of the public Fulcio instance of less than 15 minutes causing temporary CI/CD pipeline delays for downstream consumers, without data loss or any invalidation of existing trust material.
Moderate	3	A significant outage of rekor.sigstore.dev exceeding one hour, violating published SLOs; or a vulnerability allowing bypass of local Cosign verification under highly specific non-default conditions while leaving the root of trust intact.
Major	4	Compromise of an automated KMS online signing key requiring immediate revocation and emergency rotation; or unauthorised write access to a core repository resulting in a malicious commit that is detected and caught prior to release.
Severe	5	Catastrophic compromise of the TUF root (trusted_root.json) or the offline hardware keys of multiple keyholders; or undetectable tampering, truncation, or silent forking of the immutable Rekor transparency log, permanently undermining the cryptographic trust foundation of the global software supply chain.

4.1.4 Risk Scoring Matrix

L \ I	1 Insignificant	2 Minor	3 Moderate	4 Major	5 Severe
5 Almost Certain	5	10	15	20	25
4 Likely	4	8	12	16	20
3 Possible	3	6	9	12	15
2 Unlikely	2	4	6	8	10
1 Rare	1	2	3	4	5

4.1.5 Risk Appetite Threshold

The risk appetite threshold for this ISMS is formally set at **10**. Any risk achieving a score of 10 or above requires mandatory entry into the Risk Treatment Plan. Any risk scoring below 10 may be formally accepted without additional treatment controls.

This threshold is deliberately set below the commonly used standard of 15, and the justification is mathematically grounded in the nature of the assets under protection. Because AST-002 (Fulcio Certificate Authority) and AST-004 (TUF Root-Signing Infrastructure) govern cryptographic trust for global ecosystems including Kubernetes admission controllers, the npm registry, and GitHub Actions, the ISMS cannot passively accept high-impact risks on the basis of low probability alone. By setting the threshold at 10, an event scored as Severe Impact (5) combined with an Unlikely Likelihood (2) produces a score of exactly 10, ensuring that catastrophic low-probability events - such as a sophisticated root key compromise or a cloud infrastructure zero-day - are mandated for treatment under this ISMS's documented risk appetite rather than being passively accepted through optimistic probability scoring.

4.1.6 Risk Treatment Options

Mitigate - Implementing technical or procedural controls to reduce the inherent risk score to an acceptable residual level.

Sigstore Example: Mitigating the risk of malicious codebase modification (Impact 4, Likelihood 3, Score 12) by enforcing strict branch protection rules, requiring multi-party code reviews via CODEOWNERS, and integrating automated SAST/DAST tooling into the GitHub Actions pipeline to detect injected malicious logic before it reaches a signed release.

Accept - Formally acknowledging that the risk score falls below the threshold of 10 and taking no additional treatment action beyond documenting the decision and the existing controls already reducing the risk.

Sigstore Example: Accepting the risk of transient minor latency spikes on rekor.sigstore.dev during massive global software release events (Impact 1, Likelihood 4, Score 4), because the cost and operational complexity of vastly over-provisioning infrastructure outweigh the business consequence of a minor, temporary delay to downstream CI/CD pipelines.

Transfer - Shifting the financial or operational burden of a specific risk to a third party via contractual, SLA, or shared responsibility mechanisms.

Sigstore Example: Transferring the risk of physical data centre compromise, hypervisor-level attacks, and hardware failure for the live public-good infrastructure (rekor.sigstore.dev, fulcio.sigstore.dev) to Google Cloud Platform (GCP) by relying on GCP's ISO 27001 and SOC 2 certified shared responsibility model, as documented in EV-008. Note: transfer to GCP does not eliminate the availability risk experienced by end-users; application-layer mitigations must be applied concurrently.

Avoid - Fundamentally altering the project's current operational roadmap, architecture, or scope to eliminate the risk surface entirely.

Sigstore Example: Avoiding the chronic risk of compromised automation tokens in CI/CD pipelines by choosing not to implement any automated signing workflows that require persistent, long-lived secrets, and instead restricting all automated signing operations exclusively to short-lived, ephemeral OIDC-authenticated contexts - eliminating the persistent secret attack surface entirely rather than adding controls around it.

4.1.7 Residual Risk Re-Scoring Process

After a Mitigate treatment is applied, the risk must be re-evaluated to determine its Residual Risk Score using the following process:

1. The Risk Owner evaluates how the applied Annex A controls affect the original scoring parameters.
2. In most mitigation scenarios, Impact remains unchanged - a compromised root key remains Severe regardless of the controls applied. Mitigation controls reduce Likelihood.
3. The new Residual Likelihood is multiplied by the original Impact to produce the Residual Risk Score: **Residual Score = Residual Likelihood × Original Impact.**
4. The Residual Risk Score must fall below the threshold of 10 to be considered acceptable.
5. If, after all feasible treatments, the Residual Score remains 10 or higher - for example, where the risk source is an external dependency entirely outside Sigstore's control - the risk cannot be passively accepted. It requires formal, documented exception sign-off directly from the Technical Steering Committee (TSC) as designated Top Management, explicitly acknowledging the systemic risk to the open-source community.

4.1.8 Risk Owner Assignment Policy

In a distributed open-source ecosystem lacking traditional employment structures, risk ownership is assigned based on established governance mandates and technical maintainer boundaries rather than corporate job titles.

Strategic and systemic risks affecting foundational trust anchors - including AST-002 (Fulcio CA) and AST-004 (TUF Root-Signing Infrastructure) - are assigned to the Technical Steering Committee (TSC) due to their ultimate governance authority over architectural decisions, or to the Security Response Committee (SRC) where the risk has an active exploitation or vulnerability response dimension. Operational and repository-specific risks - such as CI/CD pipeline integrity (AST-008) or localised infrastructure availability (AST-006) - are assigned to the designated Maintainer Group of the relevant repository, who possess the direct administrative and code-merge authority required to execute remediation controls.

4.2 Technical Risk Register

4.2a - Risk Register: Identification

Risk ID	Affected Asset	Threat Scenario	Vulnerability / Root Cause	Likelihood	Impact	Risk Score	Treatment Required?
RR-001	AST-004 - TUF Root-Signing Infrastructure	Compromise of one or more community keyholders' offline hardware tokens through physical theft, sophisticated malware targeting the signing workstation during a ceremony, or insider collusion, with the intent of accumulating sufficient signatures to authorise an unauthorised root rotation.	The 3-of-5 signature threshold makes a single compromise insufficient, significantly lowering likelihood. However, it creates a dangerous two-keyholder-silent-compromise asymmetry - if two keys are silently compromised, the ecosystem remains entirely unaware that the root of trust is just one breach away from a catastrophic, undetectable rotation.	1 - Rare	5 - Severe	5	NO
RR-002	AST-002 - Fulcio Certificate Authority	Exploitation of a flaw in Fulcio's OIDC token validation logic, allowing an attacker to obtain a cryptographically legitimate certificate binding their public key to a victim's identity, enabling identity-spoofed artifact signing that passes downstream signature verification.	OIDC parsing is highly complex; failure to strictly enforce identity claims and audience scopes could allow an attacker to spoof identities, entirely breaking the trust foundation for Kubernetes Admission Controllers (e.g., Kyverno), the npm registry, and GitHub Actions Artifact Attestations.	2 - Unlikely	5 - Severe	10	YES
RR-003	AST-003 - Rekor Transparency Log	Bypass or corruption of the Merkle tree consistency proof mechanism, enabling silent insertion, modification, or suppression of log entries in a way that	Downstream clients failing to independently verify the Signed Tree Head (STH) prior to trusting a record. The public visibility of the log and automated STH gossiping	2 - Unlikely	5 - Severe	10	YES

Risk ID	Affected Asset	Threat Scenario	Vulnerability / Root Cause	Likelihood	Impact	Risk Score	Treatment Required?
		is undetectable to clients that do not independently verify signed tree heads.	significantly reduces the likelihood of successful silent tampering, but reliance on unverified inclusion proofs exposes clients to targeted spoofing.				
RR-004	AST-008 - GitHub CI/CD Workflow Pipelines	Injection of malicious code or supply chain compromise via a dependency confusion attack, compromised third-party GitHub Action, or misconfigured workflow permission scope, resulting in the signing of a malicious release artifact with Sigstore's production signing identity.	The deliberate absence of the pull_request_target trigger in the workflows successfully mitigates direct external PR execution. However, over-privileged workflow scopes or internal dependency updates still provide an attack vector for dependency confusion or compromised third-party Actions.	3 - Possible	4 - Major	12	YES
RR-005	AST-006 - Sigstore Public-Good Infrastructure (GCP)	Extended unavailability of rekor.sigstore.dev or fulcio.sigstore.dev due to GCP regional outage, sustained DDoS, or database infrastructure failure, causing cascading CI/CD pipeline failures across the global ecosystem of downstream relying parties.	Single cloud provider (GCP) reliance combined with massive global CI/CD traffic that often lacks standardised client backoff/jitter logic, leaving the infrastructure vulnerable to accidental self-inflicted DDoS during high-volume global release periods.	4 - Likely	3 - Moderate	12	YES

4.2b - Risk Register: Treatment & Residual

Risk ID	Treatment Option	Annex A Control(s)	Risk Owner	Residual Likelihood	Residual Score	Residual Acceptable?
RR-001	Accept	No additional controls required. Existing control: A.8.24 (Use of Cryptography) - the TUF 3-of-5 threshold signing architecture inherently reduces exploitation likelihood to Rare. Risk accepted by TSC with documented awareness of the two-keyholder silent compromise asymmetry.	TSC	1 - Rare	5	YES
RR-002	Mitigate	A.8.28 (Secure Coding), A.5.17 (Authentication Information), A.8.29 (Security Testing in Development and Acceptance)	SRC	1 - Rare	5	YES
RR-003	Mitigate	A.8.24 (Use of Cryptography), A.8.15 (Logging), A.8.16 (Monitoring Activities)	TSC	1 - Rare	5	YES
RR-004	Mitigate	A.8.8 (Management of Technical Vulnerabilities), A.8.9 (Configuration Management), A.8.32 (Change Management)	Cosign Maintainer Group	2 - Unlikely	8	YES
RR-005	Transfer / Mitigate	A.5.19 (Supplier Relationships), A.8.14 (Redundancy of Information Processing Facilities)	Infrastructure Maintainer Group	2 - Unlikely	6	YES

4.3 Risk Treatment Plan (Clause 6.1.3)

The following risk treatment plan documents the selected treatment option for each identified risk, the Annex A controls implementing that treatment, and the resulting residual risk position following treatment application. Treatment selections were made in accordance with the risk appetite threshold of 10 established in Section 4.1. All treatment decisions have been reviewed and accepted by the designated Risk Owner for each entry. The implementation status of each treatment control is confirmed in the Statement of Applicability (Appendix A) and verified in the Stage 2 Evidence Verification findings (Section 7).

Risk ID	Affected Asset	Treatment Option	Justification for Treatment Selection	Annex A Control(s) Implementing Treatment	Risk Owner	Residual Score	Treatment Status
RR-001	AST-004 - TUF Root-Signing Infrastructure	Accept	The inherent 3-of-5 threshold signing architecture reduces the likelihood of successful exploitation to Rare (1), producing a risk score of 5 which falls below the documented risk appetite threshold of 10. The existing A.8.24 cryptographic architecture is the operative control. No additional treatment is required or proportionate.	A.8.24 - Use of Cryptography (existing control, no new implementation required)	TSC	5 - Acceptable	Confirmed - existing control verified Conforming in Stage 2
RR-002	AST-002 - Fulcio Certificate Authority	Mitigate	A score of 10 mandates treatment under the documented risk appetite. The risk of OIDC identity spoofing is mitigated by enforcing secure coding standards on validation logic, rigorous authentication information controls, and continuous automated fuzz testing of critical parsing paths.	A.8.28 (Secure Coding), A.5.17 (Authentication Information), A.8.29 (Security Testing in Development and Acceptance)	SRC	5 - Acceptable	Confirmed - all three controls verified Conforming in Stage 2
RR-003	AST-003 - Rekor Transparency Log	Mitigate	A score of 10 mandates treatment. The risk of Merkle tree bypass is mitigated by the cryptographic integrity architecture of the log itself, supplemented by tamper-evident logging controls and continuous automated monitoring of signed tree head consistency.	A.8.24 (Use of Cryptography), A.8.15 (Logging), A.8.16 (Monitoring Activities)	TSC	5 - Acceptable	Confirmed - all three controls verified Conforming in Stage 2

Risk ID	Affected Asset	Treatment Option	Justification for Treatment Selection	Annex A Control(s) Implementing Treatment	Risk Owner	Residual Score	Treatment Status
RR-004	AST-008 - GitHub CI/CD Workflow Pipelines	Mitigate	A score of 12 mandates treatment. The risk of supply chain injection via CI/CD pipeline compromise is mitigated through automated vulnerability scanning of dependencies, strict configuration management of workflow permission scopes, and enforced change management controls on all code and infrastructure modifications.	A.8.8 (Management of Technical Vulnerabilities), A.8.9 (Configuration Management), A.8.32 (Change Management)	Cosign Maintainer Group	8 - Acceptable	Confirmed - all three controls verified Conforming in Stage 2
RR-005	AST-006 - Sigstore Public-Good Infrastructure (GCP)	Transfer / Mitigate	A score of 12 mandates treatment. Physical infrastructure and hypervisor-layer risks are transferred to GCP via the shared responsibility model and ISO 27001 / SOC 2 certified SLA. Application-layer availability risks are concurrently mitigated through redundant multi-regional deployments and database read replica scaling that cannot be transferred to GCP.	A.5.19 (Supplier Relationships), A.8.14 (Redundancy of Information Processing Facilities)	Infrastructure Maintainer Group	6 - Acceptable	Confirmed - both controls verified Conforming in Stage 2

4.4 Statement of Applicability (Clause 6.1.3d)

The complete SoA addressing all 93 Annex A controls is provided in Appendix A.

5. Support & Operational Planning (Clauses 7 & 8)

5.1 Resources & Competence (Clauses 7.1 & 7.2)

The resources required to maintain the ISMS are not defined by a traditional corporate budget, but rather through foundational sponsorship and community commitment. The live public-good infrastructure running on GCP is funded and provisioned through the OpenSSF, with base cloud infrastructure managed via Terraform and supported by a coalition of member companies including Google, GitHub, and Chainguard, who volunteer engineering time for on-call rotations (EV-008). Competence for those interacting with the system is strictly defined by the project's governance model: elevation to Maintainer requires a documented three-month history of active contribution and formal approval by the TSC (EV-011), while Security Response Committee members are selected specifically based on demonstrated codebase and operational security expertise (EV-003). Both the technical resources and the competence requirements for securing the ISMS are therefore formally established and adequate for the project's defined scope.

5.2 Awareness & Communication (Clauses 7.3 & 7.4)

Security awareness is embedded asynchronously into the contributor lifecycle, primarily through the mandatory reading of SECURITY.md and adherence to the OpenSSF Code of Conduct, which sets the behavioural standard for all project participants (EV-003, EV-011). However, as noted in the Statement of Applicability at A.6.3, a minor documentation gap exists regarding a formal onboarding acknowledgement checklist to explicitly verify that new maintainers have absorbed these security expectations. External communication regarding security is highly structured: TSC meeting minutes are public, and the disclosure of vulnerabilities follows a strict, documented coordinated process (EV-003). While internal communication between TSC and SRC members occurs via private channels - which is appropriate and necessary for embargoed security-sensitive content - this inherent lack of public auditability is recognised as a documented and justified exception to the project's otherwise radically transparent communication posture.

5.3 Documented Information (Clause 7.5)

The ISMS relies on a robust body of documented information, including the foundational information security policy established by SECURITY.md (EV-003) and the Technical Charter (EV-001), as well as operational procedures encompassing the root-signing ceremony runbooks (EV-004) and contributor lifecycle guidelines (EV-011). The results of the risk assessment and the Statement of Applicability are formally recorded within this overarching audit report. However, a structural deficiency exists: Sigstore's ISMS-relevant documentation is distributed across multiple individual repositories without a centralised ISMS document registry. Because there is no single, unified location where all ISMS documentation is catalogued, versioned, and holistically access-controlled, the project does not fully satisfy the stringent document control requirements of Clause 7.5. This structural deficiency is flagged as a finding candidate requiring formal assessment during Stage 2 evidence verification, with a potential Minor NCR to be raised in Phase 6 pending confirmation.

5.4 Operational Planning & Control (Clause 8.1)

Operational controls are deeply embedded into the engineering lifecycle, with signed releases and SLSA Level 3 provenance attestations consistently applied via automated CI/CD pipelines across the core components Cosign, Rekor, and Fulcio (EV-006). The vulnerability management process is not merely a documented policy but a demonstrably functioning control; the 24-hour triage SLA and private advisory workflow (EV-003) are evidenced by a historical record of closed GitHub Security Advisories that have successfully navigated the embargo and CVE request pipeline (EV-009). Furthermore, the root-signing ceremony exercises rigorous operational control over the project's most sensitive asset (AST-004), enforcing strict offline hardware requirements, cryptographic 3-of-5 threshold enforcement, and maintaining publicly accessible witnessing records and recordings to assure the ongoing integrity of the cryptographic trust anchor (EV-004).

5.5 Risk Treatment Implementation (Clause 8.3)

The implementation of the planned risk treatments documented in the Phase 2 Risk Register is confirmed across all five identified risk scenarios. For RR-001, the acceptance decision is formally recorded by the TSC, acknowledging that the existing A.8.24 TUF threshold architecture is the operative control and no additional treatment is required. For RR-002, the mitigation strategy is actively implemented via A.8.28, A.5.17, and A.8.29, evidenced specifically by the active integration of OSS-Fuzz for continuous security testing of Fulcio's OIDC token validation logic. For RR-003, mitigation is achieved through the implementation of A.8.24, A.8.15, and A.8.16, with Prometheus and Grafana serving as the operative monitoring and detection mechanisms for log integrity anomalies. For RR-004, the mitigation relies on A.8.8, A.8.9, and A.8.32, where the verifiable absence of the pull_request_target trigger from Cosign workflows demonstrates a specific and confirmed implementation of configuration management under A.8.9. For RR-005, the transfer and mitigate strategy is implemented via A.5.19 and A.8.14, with the database read replica scaling documented in historical incident post-mortems serving as operative evidence of active redundancy implementation (EV-013).

6. Performance Evaluation (Clause 9)

6.1 Monitoring, Measurement & Evaluation (Clause 9.1)

Sigstore actively monitors its security posture through several operational metrics, including CVE response times measured against the documented 24-hour acknowledgement SLA (EV-003, EV-009) and continuous automated Signed Tree Head (STH) gossiping between independent log monitors to ensure Rekor log integrity (EV-004, EV-007). Furthermore, infrastructure availability is actively tracked via the status.sigstore.dev incident history (EV-013), and the project's overall supply-chain security is continuously evaluated via OpenSSF Scorecard automated scoring (EV-012). However, while these metrics exist as robust operational practices, there is no formally documented monitoring programme owned by the TSC with scheduled review cycles, defined metric owners, and recorded evaluation outputs. Consequently, this gap is flagged as a finding candidate requiring formal classification in Phase 6, rather than being raised as a formal Non-Conformity (NCR) at this stage.

6.2 Internal Audit Evidence (Clause 9.2)

To compensate for traditional corporate audit structures, Sigstore relies on continuous automated scoring via the OpenSSF Scorecard (EV-012), structured self-assessment through the OpenSSF Best Practices Badge (EV-005), and public TSC meetings where the security posture is informally discussed. While highly valuable, these compensating mechanisms do not constitute a formal internal audit programme under Clause 9.2 because they rely on automated tools and informal discussions rather than planned, scoped, and documented audit cycles conducted by competent, independent auditors at defined intervals. Because Clause 9.2 is a mandatory requirement of the standard rather than a suggested practice, the absence of a structured internal audit programme is explicitly flagged as a Minor NCR candidate.

6.3 Management Review (Clause 9.3)

There are strong positive indicators of leadership engagement, as public TSC meetings routinely address core security architecture decisions and public GitHub discussions demonstrate TSC-level involvement with the project's security posture. However, no evidence exists of a formal, scheduled ISMS management review that explicitly incorporates the five mandatory Clause 9.3 documented inputs: the status of actions from previous reviews, changes in external and internal issues, security performance and measurement results, nonconformity and corrective action status, and a resource adequacy assessment. Because informal TSC governance meetings do not satisfy this strict requirement, this omission is flagged as a finding candidate for Phase 6, and is highly likely to be classified as a Minor NCR given that it violates a mandatory clause requirement.

7. Stage 2 Evidence Verification (Annex A Controls)

This section documents the results of Stage 2 evidence verification conducted against the applicable Annex A controls designated as relevant within the Statement of Applicability (Appendix A). All evidence was obtained exclusively from publicly available sources as indexed in Appendix B. Verification findings are classified as Conforming, Partially Conforming, or Non-Conforming against the requirements of ISO/IEC 27001:2022 Annex A. All Non-Conforming and Partially Conforming findings identified in this section are carried forward for formal classification and NCR raising in Phase 6 (Section 8).

7.1 Organisational Controls (A.5.1 – A.5.37)

The following table documents Stage 2 evidence verification findings for applicable Organisational controls - covering controls identified as Not Implemented or Partially Implemented in the Statement of Applicability, and risk-register-linked Organisational controls verified as Conforming in Stage 2.

Control ID	Evidence Examined	Evidence Reference	Verification Finding	Basis for Finding
A.5.5	Community repository, SECURITY.md, Project Charter	EV-001, EV-003	Non-Conforming	Searched the community repository, SECURITY.md, and Charter. Confirmed no documented procedure exists for engaging law enforcement or regulatory authorities.
A.5.7	All public Sigstore documentation	EV-001, EV-003, EV-007	Non-Conforming	Searched for references to threat intelligence feeds, adversary monitoring, or TTP tracking. Confirmed no proactive threat intelligence process exists beyond passive CVE receipt via GitHub Security Advisories.
A.5.29	Runbooks, test records, infrastructure documentation	EV-004, EV-008	Non-Conforming	Searched for continuity assurance testing documentation. Confirmed no runbook, test record, or procedure exists confirming security controls remain operational during a GCP outage scenario.
A.5.30	status.sigstore.dev, community repository	EV-013, EV-003	Non-Conforming	Searched for continuity planning documentation. Confirmed no formal Disaster Recovery plan with defined Recovery Time Objectives (RTO) or Recovery Point Objectives (RPO) has been published, despite effective reactive incident response being evidenced.
A.5.12 & A.5.13	GitHub visibility settings, Security Advisory metadata	EV-003, EV-009	Partially Conforming	Confirmed the implicit public/private classification scheme exists via GitHub visibility settings and Security Advisory metadata. Gap: no formal written classification policy or labelling schema has been published.
A.5.34	Sigstore Privacy Policy	EV-007	Partially Conforming	Confirmed the Sigstore Privacy Policy exists and references PII handling. Gap: the GDPR Article 17 right to erasure cannot be satisfied for email addresses recorded in the Rekor

Control ID	Evidence Examined	Evidence Reference	Verification Finding	Basis for Finding
				transparency log due to the architectural immutability requirement.
A.5.35	Trail of Bits 2022 audit report	EV-014	Partially Conforming	Confirmed the Trail of Bits 2022 audit report is publicly accessible and covers the Sigstore ecosystem. Gap: the most recent independent third-party security review is three years old and no subsequent audit has been publicly disclosed.
A.5.17	Security policy documentation, root-signing repository	EV-003, EV-004	Conforming	Mandatory GitHub 2FA enforcement for organisation members is documented in project security policies. The root-signing repository explicitly mandates hardware tokens for all TUF keyholders.
A.5.19	Infrastructure documentation, incident post-mortems	EV-008, EV-013	Conforming	GCP shared responsibility model confirmed as the operative supplier relationship framework. Infrastructure documentation and post-mortem records confirm GCP multi-regional deployment is active under the supplier arrangement.

7.2 People Controls (A.6.1 – A.6.8)

The following table documents Stage 2 evidence verification findings for the applicable People control identified as Partially Implemented in the Statement of Applicability. All remaining People controls were assessed as either Implemented or excluded from scope per Clause 4.3.

Control ID	Evidence Examined	Evidence Reference	Verification Finding	Basis for Finding
A.6.3	SECURITY.md, Code of Conduct	EV-003, EV-011	Partially Conforming	Confirmed SECURITY.md and Code of Conduct exist as awareness documents. Gap: no formal maintainer onboarding checklist requiring explicit acknowledgement of security expectations exists in any repository.

7.3 Physical Controls (A.7.1 – A.7.14)

All 14 Physical controls are formally excluded from the scope of this ISMS assessment per the scope boundary defined in Clause 4.3 and documented in the Statement of Applicability (Appendix A). No Stage 2 evidence verification is required for this domain. Physical security of the live production infrastructure is the responsibility of Google Cloud Platform under the shared responsibility model (EV-008), addressed within this ISMS via Organisational control A.5.23.

7.4 Technological Controls (A.8.1 – A.8.34)

The following table documents Stage 2 evidence verification findings for Technological controls, covering all risk-register-linked controls, Not Implemented controls, and Partially Implemented controls identified in the Statement of Applicability.

Control ID	Evidence Examined	Evidence Reference	Verification Finding	Basis for Finding
A.8.24	Root-signing repository structure, architecture documentation	EV-004, EV-007	Conforming	The 3-of-5 threshold configuration is explicitly documented within the sigstore/root-signing repository. Architecture documentation details Rekor's Merkle tree and signed tree head mechanisms, satisfying cryptographic operational control requirements.
A.8.28	CI/CD workflow files across core repositories	EV-006	Conforming	Examination of CI/CD workflow files confirms that golangci-lint and CodeQL are configured as mandatory status checks required to pass prior to merging code, actively enforcing secure coding standards.
A.8.29	OSS-Fuzz integrated projects list, CI/CD configurations	EV-006, EV-015	Conforming	Sigstore is confirmed as integrated into the OSS-Fuzz programme (EV-015), demonstrating continuous automated fuzz testing of core components including Fulcio's OIDC token validation logic.
A.8.15	Infrastructure documentation, Terraform configurations	EV-006, EV-008	Conforming	Infrastructure documentation and Terraform configurations explicitly reference GCP Cloud Logging for secure aggregation and retention of operational logs.
A.8.16	Architecture and infrastructure documentation	EV-007	Conforming	Architecture documentation confirms the integration and active use of Prometheus and Grafana for continuous system health monitoring and API anomaly detection.
A.8.8	Core repository CI/CD configurations	EV-006	Conforming	The .github/dependabot.yml configuration files are verified as present across the Cosign, Rekor, and Fulcio repositories, confirming automated dependency management and vulnerability detection are actively implemented.
A.8.9	CI/CD workflow configurations	EV-006	Conforming	CI/CD workflow configurations demonstrate the deliberate absence of pull_request_target triggers in Cosign. Workflow permission scopes are explicitly set to minimum required access, enforcing strict configuration management controls.
A.8.32	Repository settings documentation, CONTRIBUTING.md	EV-006, EV-011	Conforming	Branch protection rules are confirmed as enforced, mandating peer reviews and passing status checks while explicitly preventing direct commits to the main branch across core

Control ID	Evidence Examined	Evidence Reference	Verification Finding	Basis for Finding
				repositories.
A.8.14	Infrastructure documentation, incident post-mortems	EV-008, EV-013	Conforming	Public infrastructure documentation and historical incident post-mortems confirm active deployment of GCP multi-regional architectures and database read replica scaling to ensure high availability and redundancy.
A.8.1	Project governance documentation, contributor guidelines	EV-003, EV-011	Non-Conforming	Confirmed no MDM policy or endpoint security requirement exists for contributor devices. This gap is inherent to the BYOD nature of the open-source distributed contributor model.
A.8.23	Project governance documentation, contributor guidelines	EV-003, EV-011	Non-Conforming	Confirmed no web filtering or outbound proxy requirement exists for maintainer devices, consistent with the fully distributed remote contributor model.
A.8.10	GCP configurations, architecture documentation	EV-007, EV-008	Partially Conforming	Confirmed GCP deletion policies exist for backend infrastructure. Gap: Rekor log entries are architecturally immutable and cannot be deleted without invalidating log cryptographic integrity, creating a by-design partial implementation.
A.8.25	CI/CD pipelines, CONTRIBUTING.md	EV-006, EV-011	Partially Conforming	Confirmed CI/CD pipelines and CONTRIBUTING.md enforce SDL practices implicitly. Gap: no consolidated standalone Secure Development Lifecycle Policy document exists independently of the distributed pipeline configurations and contribution guidelines.

8. NCRs, CAPA & Certification Recommendation (Clause 10)

8.1 Non-Conformity Classification

Non-conformities identified during this audit are classified according to the following definitions. A Major NCR represents a complete absence of a required control or a systematic failure across multiple related controls that constitutes a fundamental breach of ISO/IEC 27001:2022 requirements - certification cannot be recommended until all Major NCRs are closed. A Minor NCR represents an isolated or partial failure of a control requirement that does not indicate systemic breakdown but must be corrected within an agreed timeframe of 90 days. An Observation or Opportunity for Improvement (OFI) represents a deviation that does not constitute a non-conformity but which the audit team recommends addressing to strengthen the ISMS posture, with a recommended completion timeframe of 180 days.

Finding Reference	Classification	Against	Risk Register Link
NCR-001	Minor NCR	A.5.5 - Contact with authorities	-
NCR-002	Minor NCR	A.5.7 - Threat intelligence	-
NCR-003	Minor NCR	A.5.29 - Information security during disruption	RR-005
NCR-004	Minor NCR	A.5.30 - ICT readiness for business continuity	RR-005
NCR-005	Minor NCR	Clause 7.5 - Documented information	-
NCR-006	Minor NCR	Clause 9.2 - Internal audit	-
OFI-001	Observation / OFI	A.5.12 & A.5.13 - Classification and labelling	-
OFI-002	Observation / OFI	A.5.34 - Privacy and protection of PII	-
OFI-003	Observation / OFI	A.5.35 - Independent review	-
OFI-004	Observation / OFI	A.6.3 - Awareness and training	-
OFI-005	Observation / OFI	A.8.10 - Information deletion	-
OFI-006	Observation / OFI	A.8.25 - Secure development life cycle	-
OFI-007	Observation / OFI	A.8.1 - User endpoint devices	-
OFI-008	Observation / OFI	A.8.23 - Web filtering	-
OFI-009	Observation / OFI	Clause 9.3 - Management review	-

8.2 Non-Conformity Reports

NCR CARD 1:

Field	Detail
NCR Reference	NCR-001
Classification	Minor NCR
ISO 27001:2022 Clause	6.1.3 - Information security risk treatment
Annex A Control	A.5.5 - Contact with authorities
Finding	No documented procedure exists for engaging law enforcement, regulatory authorities, or supervisory bodies in the event of a significant security incident.
Evidence of Non-Conformity	EV-001, EV-003 - review of Charter and SECURITY.md confirmed no authority contact procedure is documented.
Required Corrective Action	Establish and document a formal communication procedure outlining when, how, and by whom external authorities should be contacted during a security incident, referencing Linux Foundation legal counsel as the escalation pathway.
Risk Register Link	-
Target Completion Date	[Report Date + 90 days]

NCR CARD 2:

Field	Detail
NCR Reference	NCR-002
Classification	Minor NCR
ISO 27001:2022 Clause	6.1.3 - Information security risk treatment
Annex A Control	A.5.7 - Threat intelligence
Finding	No proactive threat intelligence process exists to gather, analyse, and apply information regarding adversary tactics, techniques, and procedures (TTPs) beyond the passive receipt of inbound CVE disclosures via GitHub Security Advisories.
Evidence of Non-Conformity	EV-001, EV-003, EV-007 - review of all public Sigstore documentation confirmed no proactive threat intelligence process exists.
Required Corrective Action	Define and implement a documented SRC process for monitoring at least one relevant external threat intelligence feed and integrating those findings into the project's risk landscape on a periodic basis.

Field	Detail
Risk Register Link	-
Target Completion Date	[Report Date + 90 days]

NCR CARD 3:

Field	Detail
NCR Reference	NCR-003
Classification	Minor NCR
ISO 27001:2022 Clause	6.1.3 - Information security risk treatment
Annex A Control	A.5.29 - Information security during disruption
Finding	There is no documented continuity assurance testing, runbook, or test record confirming that required information security controls remain fully operational during a GCP outage or similar infrastructure disruption event.
Evidence of Non-Conformity	EV-004, EV-008 - review of infrastructure and operational documentation confirmed no continuity assurance testing record exists.
Required Corrective Action	Document and periodically test procedures to verify that core security controls including access management, cryptographic key protection, and logging remain enforced and operational during adverse infrastructure disruption scenarios.
Risk Register Link	RR-005
Target Completion Date	[Report Date + 90 days]

NCR CARD 4:

Field	Detail
NCR Reference	NCR-004
Classification	Minor NCR
ISO 27001:2022 Clause	6.1.3 - Information security risk treatment
Annex A Control	A.5.30 - ICT readiness for business continuity
Finding	No formal Disaster Recovery plan has been published that defines specific Recovery Time Objectives (RTO) and Recovery Point Objectives (RPO) for the rekor.sigstore.dev and fulcio.sigstore.dev public-good infrastructure.
Evidence of Non-	EV-013, EV-003 - review of status.sigstore.dev and community repository

Field	Detail
Conformity	confirmed no formal DR plan with RTO and RPO targets has been published, despite effective reactive incident response being evidenced in post-mortem records.
Required Corrective Action	Develop, approve, and test a formal ICT Business Continuity and Disaster Recovery plan defining specific and acceptable RTO and RPO targets for all core public-good services.
Risk Register Link	RR-005
Target Completion Date	[Report Date + 90 days]

NCR CARD 5:

Field	Detail
NCR Reference	NCR-005
Classification	Minor NCR
ISO 27001:2022 Clause	7.5 - Documented information
Annex A Control	-
Finding	ISMS documentation is currently distributed across multiple GitHub repositories without a central document registry to catalogue, version, and control the ISMS documentation as a unified body, failing to satisfy the document control requirements of Clause 7.5.
Evidence of Non-Conformity	EV-001, EV-003, EV-004, EV-011 - confirmed that documentation is distributed across multiple repositories with no central registry in existence.
Required Corrective Action	Create and maintain a centralised ISMS document registry - a dedicated governance repository or index - that explicitly tracks, versions, and links all security-relevant policies and procedures to satisfy Clause 7.5 document control requirements.
Risk Register Link	-
Target Completion Date	[Report Date + 90 days]

NCR CARD 6:

Field	Detail
NCR Reference	NCR-006

Field	Detail
Classification	Minor NCR
ISO 27001:2022 Clause	9.2 - Internal audit
Annex A Control	-
Finding	Current continuous automated scoring tools and informal TSC security discussions do not constitute a formal internal audit programme involving planned, scoped, and documented audit cycles conducted by competent, independent auditors at defined intervals, as required by Clause 9.2.
Evidence of Non-Conformity	EV-005, EV-012 - compensating mechanisms reviewed and confirmed insufficient to satisfy the mandatory requirements of Clause 9.2.
Required Corrective Action	Establish and document a formal internal ISMS audit programme defining audit frequency, scope, auditor competence requirements, and required recorded outputs including audit reports and corrective action tracking.
Risk Register Link	-
Target Completion Date	[Report Date + 90 days]

OFI CARD 1:

Field	Detail
OFI Reference	OFI-001
Classification	Observation / OFI
ISO 27001:2022 Clause	6.1.3 - Information security risk treatment
Annex A Control	A.5.12 - Classification of information & A.5.13 - Labelling of information
Finding	While an implicit public/private classification scheme is effectively maintained via GitHub visibility settings and Security Advisory metadata, no formal written classification policy or labelling schema has been published.
Evidence of Observation	EV-003, EV-009 - review of repositories confirmed implicit tagging exists but a formal schema is absent.
Recommended Action	Formalise and publish the implicit data classification and labelling schema within the project's central security documentation.
Risk Register Link	-
Target Completion Date	[Report Date + 180 days]

OFI CARD 2:

Field	Detail
OFI Reference	OFI-002
Classification	Observation / OFI
ISO 27001:2022 Clause	6.1.3 - Information security risk treatment
Annex A Control	A.5.34 - Privacy and protection of PII
Finding	The Sigstore Privacy Policy governs PII handling, but the GDPR Article 17 right to erasure cannot be satisfied for email addresses recorded in the Rekor transparency log due to the project's strict architectural immutability requirement.
Evidence of Observation	EV-007 - review of transparency log architecture confirmed the deletion impossibility constraint.
Recommended Action	Update the Privacy Policy with more explicit disclaimers regarding the technical impossibility of log erasure to ensure fully informed consent before certificate issuance.
Risk Register Link	-
Target Completion Date	[Report Date + 180 days]

OFI CARD 3:

Field	Detail
OFI Reference	OFI-003
Classification	Observation / OFI
ISO 27001:2022 Clause	9.1 - Monitoring, measurement, analysis and evaluation
Annex A Control	A.5.35 - Independent review of information security
Finding	The most comprehensive independent third-party security review of the Sigstore ecosystem, conducted by Trail of Bits, is currently three years old. No subsequent full-scope independent audit has been publicly disclosed since 2022.
Evidence of Observation	EV-014 - review of the 2022 Trail of Bits report confirmed it as the most recent publicly available independent assessment.
Recommended Action	Schedule and commission a new independent third-party security review to assess the significant architectural updates introduced over the past three years.
Risk Register Link	-

Field	Detail
Target Completion Date	[Report Date + 180 days]

OFI CARD 4:

Field	Detail
OFI Reference	OFI-004
Classification	Observation / OFI
ISO 27001:2022 Clause	7.3 - Awareness
Annex A Control	A.6.3 - Information security awareness, education and training
Finding	Awareness documents exist including SECURITY.md and the Code of Conduct, but no formal onboarding checklist exists requiring a new maintainer's explicit, recorded acknowledgement of these security expectations.
Evidence of Observation	EV-003, EV-011 - review of maintainer guidelines confirmed absence of a formal acknowledgement mechanism.
Recommended Action	Implement a documented onboarding issue template or checklist for newly elevated maintainers to formally record their acknowledgement of project security policies.
Risk Register Link	-
Target Completion Date	[Report Date + 180 days]

OFI CARD 5:

Field	Detail
OFI Reference	OFI-005
Classification	Observation / OFI
ISO 27001:2022 Clause	6.1.3 - Information security risk treatment
Annex A Control	A.8.10 - Information deletion
Finding	GCP deletion policies are active for standard backend infrastructure data, but Rekor transparency log entries are architecturally immutable and cannot be deleted without invalidating log cryptographic integrity, representing a by-design partial implementation.
Evidence of Observation	EV-007, EV-008 - review of transparency log properties and GCP configuration confirmed deletion impossibility for log entries.

Field	Detail
Recommended Action	Formally document the architectural immutability of the transparency log as a permanent, approved exception to standard information deletion lifecycle policies within the ISMS.
Risk Register Link	-
Target Completion Date	[Report Date + 180 days]

OFI CARD 6:

Field	Detail
OFI Reference	OFI-006
Classification	Observation / OFI
ISO 27001:2022 Clause	6.1.3 - Information security risk treatment
Annex A Control	A.8.25 - Secure development life cycle
Finding	CI/CD pipelines and contribution guidelines implicitly enforce strong SDL practices, but no consolidated standalone Secure Development Lifecycle Policy document exists independently of the distributed pipeline configurations and contribution guidelines.
Evidence of Observation	EV-006, EV-011 - review of pipeline files and contribution guidelines confirmed implicit but unconsolidated SDL controls.
Recommended Action	Consolidate the existing highly effective distributed SDL practices into a single formally approved Secure Development Lifecycle Policy document.
Risk Register Link	-
Target Completion Date	[Report Date + 180 days]

OFI CARD 7:

Field	Detail
OFI Reference	OFI-007
Classification	Observation / OFI
ISO 27001:2022 Clause	6.1.3 - Information security risk treatment
Annex A Control	A.8.1 - User endpoint devices

Field	Detail
Finding	No baseline MDM policy or endpoint security requirement exists for maintainer devices, which is inherent to and inseparable from the BYOD nature of the distributed open-source contributor model.
Evidence of Observation	EV-011 - review of contributor guidelines confirmed no endpoint device constraints are enforced.
Recommended Action	Formally document a risk acceptance decision regarding endpoint devices or draft recommended voluntary baseline endpoint security guidelines for maintainers handling privileged repository access.
Risk Register Link	-
Target Completion Date	[Report Date + 180 days]

OFI CARD 8:

Field	Detail
OFI Reference	OFI-008
Classification	Observation / OFI
ISO 27001:2022 Clause	6.1.3 - Information security risk treatment
Annex A Control	A.8.23 - Web filtering
Finding	No web filtering, DNS filtering, or outbound proxy requirement exists to protect maintainers, which is consistent with and inherent to the fully distributed remote contributor model.
Evidence of Observation	EV-011 - review of contributor guidelines confirmed absence of network traffic restrictions for maintainer environments.
Recommended Action	Document an explicit risk treatment exception formally acknowledging the distributed operational model's structural incompatibility with centralised web filtering controls.
Risk Register Link	-
Target Completion Date	[Report Date + 180 days]

OFI CARD 9:

Field	Detail
OFI Reference	OFI-009
Classification	Observation / OFI
ISO 27001:2022 Clause	9.3 - Management review
Annex A Control	-
Finding	No evidence exists of a formal scheduled ISMS management review cycle that explicitly processes the mandatory Clause 9.3 inputs including status of previous actions, changes in external and internal issues, security performance results, nonconformity status, and resource adequacy assessment. Informal TSC governance meetings do not satisfy this requirement.
Evidence of Observation	EV-001, EV-003 - review of TSC governance documentation and meeting records confirmed informal discussions do not satisfy the mandatory Clause 9.3 input requirements.
Recommended Action	Establish a formal annual ISMS management review cycle that explicitly addresses all mandatory Clause 9.3 inputs and documents the resulting security posture decisions and resource commitments.
Risk Register Link	-
Target Completion Date	[Report Date + 180 days]

8.3 CAPA Plan

The following Corrective Action and Preventive Action plan documents the root cause, assigned remediation owner, target date, and verification method for each of the six Minor NCRs identified during this audit. Corrective action closure will be confirmed upon submission of objective evidence to the audit team within the stipulated 90-day period.

NCR Ref	Root Cause	Corrective Action	Responsible Party	Target Date	Verification Method
NCR-001	No formal escalation pathway to external authorities was established when the security governance model was designed, as the open-source community model assumed informal reliance on Linux Foundation legal counsel.	Document a formal authority contact procedure specifying trigger conditions, responsible contact roles, and Linux Foundation legal escalation pathway.	TSC	Report Date + 90 days	Procedure document published in community repository and referenced in SECURITY.md

NCR Ref	Root Cause	Corrective Action	Responsible Party	Target Date	Verification Method
NCR-002	The SRC's reactive posture relies exclusively on inbound CVE disclosures and has no documented mandate or process for outbound proactive threat monitoring against cryptographic infrastructure threat actors.	Define and implement a documented SRC process for monitoring at least one relevant threat intelligence feed and integrating findings into the periodic risk review cycle.	SRC	Report Date + 90 days	Documented process published in community repository with evidence of first execution cycle
NCR-003	No continuity assurance testing has been conducted or documented to confirm that access management, logging, and cryptographic controls remain operational during a GCP regional outage scenario.	Document and execute at least one tabletop or technical test confirming security control continuity during a simulated GCP disruption event.	Infrastructure Maintainer Group	Report Date + 90 days	Published test record or post-exercise report confirming control continuity during simulated disruption
NCR-004	No formal DR plan defining service recovery objectives has been published for the public-good infrastructure despite effective reactive incident response being demonstrated through historical post-mortems.	Develop, approve, and publish a formal ICT Business Continuity and Disaster Recovery plan for rekor.sigstore.dev and fulcio.sigstore.dev with specific RTO and RPO targets.	TSC and Infrastructure Maintainer Group	Report Date + 90 days	Formal DR plan document published in community or infrastructure repository
NCR-005	ISMS-relevant documentation grew organically across multiple component repositories without a centralised registry, consistent with the project's distributed development model but non-compliant with Clause 7.5 document control requirements.	Create and maintain a centralised ISMS document registry cataloguing, versioning, and linking all security-relevant policies and procedures as a unified controlled body.	TSC	Report Date + 90 days	Registry published and confirmed to reference all documents listed in Appendix B of this report
NCR-006	No formal internal ISMS audit programme has been established. Automated scoring tools and informal TSC	Establish and document a formal internal audit programme defining scope, frequency of at	TSC	Report Date + 90 days	Published internal audit programme document and evidence of first scheduled audit

NCR Ref	Root Cause	Corrective Action	Responsible Party	Target Date	Verification Method
	discussions have served as compensating mechanisms but do not satisfy the mandatory Clause 9.2 programme requirements.	least annually, auditor competence requirements, and required recorded outputs including audit reports and action tracking.			cycle initiation

8.4 Formal Certification Recommendation

Based on the evidence gathered during this simulated desk review of the Sigstore project's Information Security Management System, I recommend that the project be granted the outcome of **CERTIFY WITH CONDITIONS**. This recommendation is firmly justified by a positive finding profile containing zero Major non-conformities, and the verified confirmation that all ten critical risk-register controls governing the ecosystem's core cryptographic trust infrastructure are fully implemented and effective. While the audit identified six Minor NCRs and nine Opportunities for Improvement, these strictly represent administrative gaps stemming from the inherent friction of applying traditional ISO 27001 requirements to a distributed, open-source operational model, rather than systemic failures of security architecture. Final certification is conditional upon the Technical Steering Committee (TSC) submitting an acceptable Corrective Action Plan addressing the six Minor NCRs within the stipulated 90-day period, with objective evidence of closure provided for each finding before the certification decision is confirmed.

Appendix A - Statement of Applicability (ISO/IEC 27001:2022 - All 93 Controls)

This SoA addresses all 93 Annex A controls. Applicability decisions are based on the ISMS scope defined in Clause 4.3 and the results of the risk assessment (Clause 6.1).

UNIVERSAL EXCLUSION JUSTIFICATION (A.7.1–A.7.14): All 14 Physical controls are formally excluded from the scope of this ISMS assessment. The Sigstore project operates as a fully distributed, open-source ecosystem with no corporate physical premises, no owned or leased office facilities, and no physical hardware under the direct control of the project governance structure. The physical security of the live production infrastructure is entirely the responsibility of Google Cloud Platform (GCP) under the shared responsibility model (EV-008), addressed within this ISMS via A.5.23. This exclusion is consistent with and derived from the ISMS scope boundary formally defined in Clause 4.3 of this report.

Control ID	Control Name	Applicable?	Justification & Evidence	Implementation Status	Risk Register Link
- ORGANISATIONAL CONTROLS (A.5.1 – A.5.37) -					
A.5.1	Policies for information security	YES	Established via the Sigstore Project Charter (EV-001) and the unified project SECURITY.md (EV-003). Both documents are formally approved and enforced by the TSC as designated top management.	Implemented	-
A.5.2	Information security roles and responsibilities	YES	Formally defined in the Technical Charter (EV-001): strategic oversight by TSC; operational incident response by SRC; repository-level management by Maintainer Groups. TSC membership and role assignments documented in EV-002.	Implemented	-
A.5.3	Segregation of duties	YES	Enforced cryptographically via TUF 3-of-5 keyholder thresholds requiring multi-party authorisation for root modifications (EV-004), and via GitHub branch protection rules requiring independent PR reviews before merging to main branches, documented in	Implemented	-

Control ID	Control Name	Applicable?	Justification & Evidence	Implementation Status	Risk Register Link
			CODEOWNERS (EV-010).		
A.5.4	Management responsibilities	YES	TSC as top management mandates security requirements, oversees project trajectory, and authorises formation of the SRC per Charter §2.g (EV-001).	Implemented	-
A.5.5	Contact with authorities	YES	No formally documented procedure exists for direct engagement with law enforcement or regulatory authorities. The project relies informally on Linux Foundation legal counsel for regulatory matters (EV-001).	Not Implemented	-
A.5.6	Contact with special interest groups	YES	Sigstore maintains continuous, structured engagement with OpenSSF and CNCF as parent standards bodies, and participates in cross-community working groups on software supply chain security per architecture documentation (EV-007).	Implemented	-
A.5.7	Threat intelligence	YES	The SRC relies passively on inbound CVE disclosures and GitHub Security Advisories (EV-003). No documented process exists for proactive monitoring of external threat intelligence feeds, adversary TTPs, or dark-web indicators of compromise targeting the Sigstore ecosystem.	Not Implemented	-
A.5.8	Information security in project management	YES	Security is embedded into the SDLC via mandatory code reviews, automated CI/CD security checks required to pass before merges, and OpenSSF Best Practices badge compliance requirements (EV-006).	Implemented	-
A.5.9	Inventory of	YES	Formally documented in the	Implemented	-

Control ID	Control Name	Applicable?	Justification & Evidence	Implementation Status	Risk Register Link
	information and other associated assets		Information Asset Register established within this ISMS (AST-001 through AST-010), as detailed in Section 3.4 of this report.		
A.5.10	Acceptable use of information and other associated assets	YES	Governed by the OpenSSF and Linux Foundation Code of Conduct, which dictates acceptable behaviour for all contributors interacting with project assets and infrastructure (EV-011, EV-001).	Implemented	-
A.5.11	Return of assets	YES	Contextualised for open-source governance: upon maintainer departure or removal, access is revoked via documented involuntary removal procedures (EV-011) encompassing GitHub RBAC de-provisioning and, where applicable, TUF key revocation ceremonies requiring threshold co-signatures (EV-004).	Implemented	-
A.5.12	Classification of information	YES	An implicit classification scheme exists operating on a public-by-default model, with private embargoed security advisories forming the confidential tier (EV-003). While effective in practice, no formally documented classification policy mapping these states has been published.	Partially Implemented	-
A.5.13	Labelling of information	YES	De facto labelling occurs via GitHub repository visibility settings and GitHub Security Advisory metadata, which restricts access to embargoed vulnerability information (EV-003). Sufficient for open-source operations but lacks a formalised labelling schema.	Partially Implemented	-
A.5.14	Information	YES	Cryptographic material and verification metadata are	Implemented	-

Control ID	Control Name	Applicable?	Justification & Evidence	Implementation Status	Risk Register Link
	transfer		securely distributed to clients via TLS-encrypted channels and the authenticated TUF client-server trust distribution architecture (EV-004, EV-007).		
A.5.15	Access control	YES	Enforced via GitHub enterprise access controls governing repository-level permissions and Terraform-managed access controls for GCP production infrastructure. Role-based access documented via CODEOWNERS (EV-010).	Implemented	-
A.5.16	Identity management	YES	Maintainer identities managed via GitHub organisational memberships with enforced 2FA. End-user identities for signing operations managed via third-party OIDC providers authenticated by Fulcio (EV-007).	Implemented	-
A.5.17	Authentication information	YES	Hardware security tokens (YubiKey or equivalent) required for all TUF root keyholders. GitHub 2FA mandated for all maintainers and SRC members (EV-003). Directly addresses the OIDC authentication vulnerability documented in RR-002.	Implemented	RR-002
A.5.18	Access rights	YES	Principle of least privilege enforced via scoped GitHub branch protection rules, minimum-permission CI/CD workflow tokens, and CODEOWNERS-enforced review requirements preventing self-approval of sensitive changes (EV-010, EV-006).	Implemented	-
A.5.19	Information security in supplier	YES	Governed by the shared responsibility model with GCP for live production infrastructure (EV-008) and	Implemented	RR-005

Control ID	Control Name	Applicable?	Justification & Evidence	Implementation Status	Risk Register Link
	relationships		with GitHub for source code hosting and CI/CD execution. Directly addresses the supplier dependency risk documented in RR-005.		
A.5.20	Addressing information security within supplier agreements	YES	Relies on standard enterprise Terms of Service and data processing agreements established between the Linux Foundation, GCP, and GitHub. Linux Foundation acts as the contracting entity on behalf of the project (EV-001, EV-008).	Implemented	-
A.5.21	Managing information security in the ICT supply chain	YES	Sigstore secures its own upstream supply chain by pinning Go module dependencies, utilising Dependabot for automated vulnerability-driven updates (EV-006), and generating SLSA Level 3 provenance attestations for its own core component releases (EV-007). Notably, Sigstore functions simultaneously as the subject of this control and as a public-good implementation of this control for the broader software ecosystem.	Implemented	-
A.5.22	Monitoring, review and change management of supplier services	YES	Automated dependency updates monitored and merged via CI/CD tooling (EV-006). However, formal structured SLA performance monitoring of GCP and GitHub service levels is reactive rather than proactively governed against documented targets (EV-008).	Partially Implemented	-
A.5.23	Information security for use of cloud services	YES	GCP confirmed as the hosting provider for live public-good infrastructure (EV-008). Managed via Terraform Infrastructure-as-	Implemented	RR-005

Control ID	Control Name	Applicable?	Justification & Evidence	Implementation Status	Risk Register Link
			Code configurations. Risk treated via concurrent mitigation (database redundancy, rate limiting) and transfer (GCP ISO 27001 and SOC 2 certified shared responsibility model).		
A.5.24	Information security incident management planning and preparation	YES	Documented via the unified SECURITY.md incident response process (EV-003), establishing the SRC as the incident management function with a formalised 24-hour acknowledgement SLA and private GitHub Security Advisory workflow for coordinated response.	Implemented	-
A.5.25	Assessment and decision on information security events	YES	SRC performs triage and severity classification of reported events and coordinates the formation of a Fix Team via private GitHub Security Advisories (EV-003, EV-009).	Implemented	-
A.5.26	Response to information security incidents	YES	Documented response workflow: patch development in private temporary forks, emergency key rotation procedures for cryptographic compromise scenarios, and CVE assignment request prior to coordinated public disclosure (EV-003, EV-009).	Implemented	-
A.5.27	Learning from information security incidents	YES	Evidenced by publicly published post-mortems following infrastructure incidents (EV-013), resulting in measurable architecture improvements including GCP database read replica scaling, implementation of stricter rate limiting, and backend query optimisation.	Implemented	-
A.5.28	Collection of evidence	YES	Intrinsic to the core architecture: Rekor provides an immutable, cryptographically verifiable evidence record of all signing	Implemented	-

Control ID	Control Name	Applicable?	Justification & Evidence	Implementation Status	Risk Register Link
			events (EV-004). Supplemented by GitHub audit logs and closed Security Advisory records (EV-009, EV-006).		
A.5.29	Information security during disruption	YES	Linked to RR-005. No documented assurance, test record, or runbook exists confirming that security access controls and cryptographic protections remain enforced and operational during a catastrophic GCP infrastructure failure or extended outage (EV-008).	Not Implemented	RR-005
A.5.30	ICT readiness for business continuity	YES	Despite publicly available post-mortems evidencing effective incident response (EV-013), no formally documented Disaster Recovery Plan has been published establishing Recovery Time Objectives (RTO) or Recovery Point Objectives (RPO) for the rekor.sigstore.dev and fulcio.sigstore.dev public-good infrastructure.	Not Implemented	RR-005
A.5.31	Legal, statutory, regulatory and contractual requirements	YES	Legal and regulatory compliance managed centrally by the Linux Foundation and LF Projects LLC, ensuring broad statutory compliance for all hosted open-source projects operating under the LF umbrella (EV-001).	Implemented	-
A.5.32	Intellectual property rights	YES	Strictly managed via Apache 2.0 licence requirements, Developer Certificate of Origin (DCO) sign-off mandated on all inbound code contributions, and Linux Foundation trademark usage guidelines (EV-001).	Implemented	-
A.5.33	Protection of	YES	The Rekor transparency log is immutable by	Implemented	-

Control ID	Control Name	Applicable?	Justification & Evidence	Implementation Status	Risk Register Link
	records		cryptographic design, preventing deletion or alteration of signing records (EV-004). GitHub repository histories are distributed and protected against force-pushes on main branches via enforced branch protection rules (EV-010).		
A.5.34	Privacy and protection of PII	YES	Fulcio extracts email addresses from OIDC tokens and binds them to X.509 certificates published into the public Rekor transparency log (EV-007). Governed by the published Sigstore Privacy Policy aligned with Linux Foundation standards. Note: an unresolved architectural tension exists between the GDPR Article 17 right to erasure and Rekor's immutable append-only design - once a signing event containing a user's email address is recorded, it cannot be deleted without invalidating log cryptographic integrity. This trade-off is acknowledged publicly but not fully resolved.	Partially Implemented	-
A.5.35	Independent review of information security	YES	Evidenced by the Trail of Bits 2022 comprehensive third-party security audit of the Sigstore ecosystem, verifying cryptographic design and implementation correctness (EV-014). Note: this audit is three years old and no subsequent independent third-party review has been publicly disclosed, representing a currency gap warranting an Observation in Phase 6.	Implemented	-
A.5.36	Compliance with policies, rules and standards for information	YES	Automated CI/CD pipelines including CodeQL static analysis, mandatory linting, and required passing test suites algorithmically enforce	Implemented	-

Control ID	Control Name	Applicable?	Justification & Evidence	Implementation Status	Risk Register Link
	security		compliance with coding and security standards before any code contribution is merged (EV-006).		
A.5.37	Documented operating procedures	YES	Runbooks for root signing ceremonies documented in the root-signing repository (EV-004); maintainer onboarding and offboarding guides documented in CONTRIBUTING.md (EV-011); local development and operational setup instructions maintained in repository READMEs and docs/ directories across core components.	Implemented	-
- PEOPLE CONTROLS (A.6.1 – A.6.8) -					
A.6.1	Screening	YES	Traditional background verification is replaced by a strict meritocratic trust model. Contributors build a public, cryptographically verifiable track record via Git commits and DCO sign-off (EV-011). Elevation to Maintainer or TUF Keyholder requires community consensus and TSC approval (EV-001). Note: formal identity verification of claimed credentials is absent - the DCO confirms legal commitment but does not verify contributor identity, representing a partial implementation.	Partially Implemented	-
A.6.2	Terms and conditions of employment	YES	Contextualised for open-source: contributors are not employees, but participation is strictly conditional upon adherence to the Developer Certificate of Origin (DCO) and the Linux Foundation and OpenSSF Code of Conduct (EV-011, EV-001). These instruments	Implemented	-

Control ID	Control Name	Applicable?	Justification & Evidence	Implementation Status	Risk Register Link
			collectively impose the security obligations that employment contracts provide in traditional organisations.		
A.6.3	Information security awareness, education and training	YES	No formal Learning Management System or mandatory annual training module exists. Security awareness is enforced asynchronously via mandatory acknowledgement of SECURITY.md (EV-003), automated CI/CD linting and security feedback loops functioning as point-in-time correction (EV-006), and architectural threat modelling in public TSC meetings. A formalised maintainer onboarding checklist requiring explicit acknowledgement of security expectations does not currently exist and would be required to achieve full implementation.	Partially Implemented	-
A.6.4	Disciplinary process	YES	Governed entirely by the OpenSSF and Linux Foundation Code of Conduct (EV-011), which documents graduated enforcement procedures for violations ranging from formal written warnings to immediate and permanent revocation of GitHub access and maintainer status. Enforcement authority rests with the TSC.	Implemented	-
A.6.5	Responsibilities after termination or change of employment	YES	Contextualised as maintainer offboarding and removal. Upon voluntary resignation or involuntary removal, all access rights including GitHub RBAC, GCP IAM roles, and TUF keyholder status are revoked per documented maintainer	Implemented	-

Control ID	Control Name	Applicable?	Justification & Evidence	Implementation Status	Risk Register Link
			lifecycle procedures (EV-011, EV-004). Post-removal confidentiality obligations apply specifically to knowledge of unpatched vulnerabilities under active embargo, consistent with the SRC disclosure process (EV-003).		
A.6.6	Confidentiality or non-disclosure agreements	YES	SRC members and contributors participating in active vulnerability embargoes operate under strict documented confidentiality expectations regarding unpatched vulnerabilities prior to coordinated CVE disclosure, as specified in SECURITY.md (EV-003). These obligations function as a targeted operational NDA. Note: no formally signed NDA instrument exists - confidentiality is a documented expectation rather than a signed legal agreement, representing a contextually appropriate but partially formal implementation.	Implemented	-
A.6.7	Remote working	YES	Sigstore is a fully distributed, 100% remote ecosystem by design. Security does not rely on physical location or corporate network perimeter controls. Access is enforced entirely via zero-trust principles: cryptographic identity via hardware security tokens for keyholders, mandatory 2FA for all maintainers, and role-based access controls on GitHub and GCP regardless of contributor location (EV-003, EV-010).	Implemented	-
A.6.8	Information security event	YES	Formally documented in the unified project SECURITY.md (EV-003). All	Implemented	-

Control ID	Control Name	Applicable?	Justification & Evidence	Implementation Status	Risk Register Link
	reporting		contributors, downstream relying parties, and external security researchers are directed to report suspected vulnerabilities via security@sigstore.dev or GitHub's private vulnerability reporting feature. Both channels explicitly trigger the SRC's documented 24-hour acknowledgement and triage SLA, with subsequent coordination via private GitHub Security Advisories (EV-003, EV-009).		
- PHYSICAL CONTROLS (A.7.1 – A.7.14) -					
A.7.1	Physical security perimeters	NO	See Universal Exclusion Justification above. Sigstore operates no physical premises. Physical perimeter security is GCP's responsibility under the shared responsibility model (EV-008).	N/A	-
A.7.2	Physical entry	NO	See Universal Exclusion Justification above. No physical facilities requiring entry controls are operated or controlled by the Sigstore project.	N/A	-
A.7.3	Securing offices, rooms and facilities	NO	See Universal Exclusion Justification above. No offices, server rooms, or facilities are owned or leased by the project.	N/A	-
A.7.4	Physical security monitoring	NO	See Universal Exclusion Justification above. No project-controlled physical premises exist requiring surveillance or monitoring.	N/A	-
A.7.5	Protecting against physical and environmental	NO	See Universal Exclusion Justification above. Environmental threat protection for production	N/A	-

Control ID	Control Name	Applicable?	Justification & Evidence	Implementation Status	Risk Register Link
	threats		infrastructure is GCP's contractual responsibility (EV-008).		
A.7.6	Working in secure areas	NO	See Universal Exclusion Justification above. No secure physical areas are defined or operated by the project. All work is conducted remotely via cryptographic access controls addressed under A.6.7.	N/A	-
A.7.7	Clear desk and clear screen	NO	See Universal Exclusion Justification above. No shared physical workspaces or offices exist within the project's operational boundary.	N/A	-
A.7.8	Equipment siting and protection	NO	See Universal Exclusion Justification above. No project-owned physical equipment requires siting or protection controls. Production hardware is GCP-managed (EV-008).	N/A	-
A.7.9	Security of assets off-premises	NO	See Universal Exclusion Justification above. No project-owned physical assets are transported off-premises. Note: TUF keyholder hardware tokens are personal devices owned by individual keyholders and fall outside the ISMS boundary as defined in Clause 4.3.	N/A	-
A.7.10	Storage media	NO	See Universal Exclusion Justification above. No physical storage media is owned, managed, or disposed of by the project. All storage is cloud-based under GCP management (EV-008).	N/A	-
A.7.11	Supporting utilities	NO	See Universal Exclusion Justification above. Power, cooling, and utility	N/A	-

Control ID	Control Name	Applicable?	Justification & Evidence	Implementation Status	Risk Register Link
			infrastructure for production services is entirely GCP's operational responsibility under the shared responsibility model (EV-008).		
A.7.12	Cabling security	NO	See Universal Exclusion Justification above. No physical cabling infrastructure is owned or managed by the Sigstore project.	N/A	-
A.7.13	Equipment maintenance	NO	See Universal Exclusion Justification above. No project-owned physical equipment requires maintenance procedures. Production infrastructure maintenance is GCP's responsibility (EV-008).	N/A	-
A.7.14	Secure disposal or re-use of equipment	NO	See Universal Exclusion Justification above. No physical equipment is owned by the project requiring secure disposal. Decommissioning of GCP storage volumes is governed by GCP's data destruction policies under the shared responsibility model (EV-008).	N/A	-
- TECHNOLOGICAL CONTROLS (A.8.1 – A.8.34) -					
A.8.1	User endpoint devices	YES	As an open-source project, contributors use unmanaged BYOD endpoints. No MDM solution or corporate endpoint security policy is enforced on maintainers' local machines. Compensating controls at A.8.5 (mandatory 2FA) and A.8.18 (hardware token requirements for keyholders) partially offset this gap but do not constitute implementation of this	Not Implemented	-

Control ID	Control Name	Applicable?	Justification & Evidence	Implementation Status	Risk Register Link
			control (EV-010, EV-003).		
A.8.2	Privileged access rights	YES	Privileged access to the public-good infrastructure is strictly governed via GCP IAM roles with least-privilege scoping. Terraform state files containing sensitive infrastructure definitions are logically isolated with elevated RBAC restricted to dedicated infrastructure maintainers (EV-008, EV-006).	Implemented	-
A.8.3	Information access restriction	YES	Read access to repositories is public by design, consistent with the open-source model. Write and merge access is strictly enforced via GitHub RBAC, explicitly mapped to designated CODEOWNERS files preventing unauthorised code changes (EV-010).	Implemented	-
A.8.4	Access to source code	YES	GitHub branch protection rules are rigidly enforced on main branches across Cosign, Rekor, and Fulcio. Rules require multiple approving PR reviews, mandatory passing of all automated status checks, and explicitly disable force-pushes, preventing direct or unreviewed modifications (EV-010, EV-006).	Implemented	-
A.8.5	Secure authentication	YES	GitHub two-factor authentication (2FA) is a mandatory requirement for all organisation members, maintainers, and TSC members. Hardware security tokens are required for TUF root keyholders, representing the highest authentication tier (EV-003).	Implemented	-
A.8.6	Capacity management	YES	GCP cloud infrastructure relies on automated horizontal scaling rules. The	Implemented	-

Control ID	Control Name	Applicable?	Justification & Evidence	Implementation Status	Risk Register Link
			Rekor API employs strict rate-limiting and database read replicas to absorb massive traffic spikes from global CI/CD pipelines, as evidenced by the post-mortem architecture improvements (EV-008, EV-013).		
A.8.7	Protection against malware	YES	Addressed at the pipeline level rather than the endpoint. Automated scanning including Go vulnerability management tooling and CodeQL runs within CI/CD pipelines to prevent injection of malicious code into final compiled binaries and release artefacts (EV-006).	Implemented	-
A.8.8	Management of technical vulnerabilities	YES	Implemented via automated dependency updates using Dependabot and continuous SAST scanning via CodeQL on all pull requests to detect vulnerable third-party dependencies before they are merged into the codebase (EV-006).	Implemented	RR-004
A.8.9	Configuration management	YES	Infrastructure is managed declaratively via Terraform Infrastructure-as-Code, ensuring all configuration changes are version-controlled and reviewed. GitHub Actions workflow files are strictly configured using the principle of least privilege with explicit minimum permission scopes (EV-006, EV-008).	Implemented	RR-004
A.8.10	Information deletion	YES	GCP lifecycle and deletion policies govern standard backend infrastructure data. However, entries in the Rekor transparency log are architecturally immutable and cannot be deleted without invalidating log	Partially Implemented	-

Control ID	Control Name	Applicable?	Justification & Evidence	Implementation Status	Risk Register Link
			cryptographic integrity - representing a by-design partial implementation of this control consistent with the architectural tension noted at A.5.34 (EV-004, EV-008).		
A.8.11	Data masking	YES	API-level parameter filtering is referenced in architectural documentation (EV-007) but no specific public configuration file confirms implementation. This requires direct verification during Stage 2 evidence review.	Partially Implemented	-
A.8.12	Data leakage prevention	YES	GitHub Advanced Security Secret Scanning is enabled across the core repositories to actively detect and block commits containing exposed private keys, OIDC bearer tokens, or infrastructure credentials before they enter the codebase (EV-006).	Implemented	-
A.8.13	Information backup	YES	The GCP backend databases powering Rekor and Fulcio utilise automated, encrypted daily backups and point-in-time recovery capabilities, managed under GCP's standard operational model (EV-008).	Implemented	-
A.8.14	Redundancy of information processing facilities	YES	Production services utilise GCP multi-regional deployments, load balancers, and database read replicas to ensure high availability during sustained load or regional failures, as evidenced by the post-mortem database scaling resolution (EV-008, EV-013).	Implemented	RR-005
A.8.15	Logging	YES	Rekor operates as the ultimate tamper-evident logging mechanism for the ecosystem via its Merkle tree architecture (EV-004). At the infrastructure level,	Implemented	RR-003

Control ID	Control Name	Applicable?	Justification & Evidence	Implementation Status	Risk Register Link
			operational logs are aggregated securely in GCP Cloud Logging for availability and security monitoring (EV-006).		
A.8.16	Monitoring activities	YES	System health and API anomalies are monitored via Prometheus and Grafana dashboards. The cryptographic integrity of the Rekor log is continuously monitored via automated Signed Tree Head (STH) gossiping between independent log monitors (EV-007, EV-004).	Implemented	RR-003
A.8.17	Clock synchronisation	YES	Fully managed by GCP infrastructure via NTP servers, ensuring absolute temporal precision for the Timestamp Authority (TSA) service and the validity windows of short-lived Fulcio X.509 certificates (EV-008).	Implemented	-
A.8.18	Use of privileged utility programs	YES	Highly sensitive offline signing utilities used for TUF root rotation require localised, isolated execution alongside physical hardware security tokens, preventing remote or automated abuse of privileged cryptographic operations (EV-004).	Implemented	-
A.8.19	Installation of software on operational systems	YES	Manual installation of software on production VMs is strictly prohibited. All deployments to the live infrastructure are orchestrated immutably via Kubernetes manifests and automated CI/CD pipelines, eliminating the risk of ad-hoc configuration drift (EV-006).	Implemented	-
A.8.20	Networks security	YES	Live services operate within segmented GCP Virtual Private Clouds (VPCs). TLS 1.3 is enforced for all inbound and outbound API	Implemented	-

Control ID	Control Name	Applicable?	Justification & Evidence	Implementation Status	Risk Register Link
			traffic to ensure encryption in transit (EV-008).		
A.8.21	Security of network services	YES	Public-facing endpoints are protected against DDoS and volumetric attacks via GCP Cloud Armor and configured ingress controllers, providing application-layer network security (EV-008).	Implemented	-
A.8.22	Segregation of networks	YES	Production and staging environments are logically and physically isolated into separate GCP projects and distinct Kubernetes clusters, preventing cross-contamination between development, testing, and live public-good infrastructure (EV-008).	Implemented	-
A.8.23	Web filtering	YES	As maintainers utilise personal, unmanaged BYOD endpoint devices, no centralised corporate web filtering or outbound proxy is applied to developers' browsing sessions. This is a known gap consistent with the open-source distributed contributor model (EV-003).	Not Implemented	-
A.8.24	Use of cryptography	YES	The foundational control of the entire ISMS. Encompasses TUF threshold signing architecture, ephemeral key generation in Cosign's keyless signing flow, Fulcio X.509 certificate issuance with 10-minute validity windows, and Rekor Merkle tree consistency and inclusion proofs ensuring transparency log integrity (EV-004, EV-007).	Implemented	RR-001, RR-003
A.8.25	Secure development life cycle	YES	Robust SDL practices including peer review, automated testing, and fuzz testing are implicitly enforced via CI/CD pipelines and CONTRIBUTING.md	Partially Implemented	-

Control ID	Control Name	Applicable?	Justification & Evidence	Implementation Status	Risk Register Link
			guidelines (EV-006, EV-011). However, a formalised, consolidated Secure Development Lifecycle Policy document does not exist independently of these distributed guidelines, representing a partial implementation.		
A.8.26	Application security requirements	YES	Security requirements are transparently defined, debated, and documented via public RFCs and GitHub issues prior to any architectural changes, ensuring security is a documented input to design decisions rather than a post-development consideration (EV-007).	Implemented	-
A.8.27	Secure system architecture and engineering principles	YES	The ecosystem is architected on zero-trust and keyless signing principles, structurally engineering away the risk of long-lived key compromise by design. Ephemeral certificate issuance replaces persistent key management as the core trust mechanism (EV-007).	Implemented	-
A.8.28	Secure coding	YES	Secure coding standards are algorithmically enforced via mandatory static analysis linters including golangci-lint, CodeQL SAST scanning, and mandatory peer code reviews before any contribution can be merged into main branches (EV-006).	Implemented	RR-002
A.8.29	Security testing in development and acceptance	YES	Extensive unit and integration tests are required for all pull requests. Critical parsing logic including Fulcio's OIDC token validation is subjected to continuous fuzz testing via integration with the OSS-Fuzz programme, providing	Implemented	RR-002

Control ID	Control Name	Applicable?	Justification & Evidence	Implementation Status	Risk Register Link
			ongoing automated security testing at scale (EV-006).		
A.8.30	Outsourced development	NO	Sigstore does not engage third-party vendors for outsourced software development. All code is produced by the open-source community and maintainers operating under the DCO and project governance model (EV-011). This control is therefore not applicable within the defined ISMS scope.	N/A	-
A.8.31	Separation of development, testing and production environments	YES	Development is performed locally on contributor machines. Testing occurs in ephemeral CI/CD runners and dedicated staging infrastructure (staging.sigstore.dev). Production is fully segregated in locked-down GCP projects with separate IAM policies preventing cross-environment access (EV-006, EV-008).	Implemented	-
A.8.32	Change management	YES	Infrastructure changes require Terraform pull requests subject to peer review and CI validation. Code changes require passing all GitHub Actions CI checks and formal maintainer approval via CODEOWNERS. Direct commits to main branches are technically prevented by enforced branch protection rules (EV-006).	Implemented	RR-004
A.8.33	Test information	YES	The project strictly uses mock OIDC tokens, synthetic test keys, and generated dummy payloads for all CI/CD test suites. Production cryptographic material, real certificates, and live Rekor log entries are never exposed or used in testing	Implemented	-

Control ID	Control Name	Applicable?	Justification & Evidence	Implementation Status	Risk Register Link
			environments (EV-006).		
A.8.34	Protection of information systems during audit testing	YES	Sigstore provisions and maintains a fully distinct staging environment (staging.sigstore.dev) mirroring production architecture. This allows external penetration testing, vulnerability research, and downstream integration testing without risking disruption to the live public-good infrastructure (EV-007).	Implemented	

Appendix B - Evidence Index & Artifact References

All evidence was obtained from publicly available sources. No confidential information was accessed. Every factual claim in this report must reference at least one entry in this index.

Evidence ID	Artifact Name	Source / Location	Relevance to Audit
EV-001	Sigstore Technical Charter	sigstore/TSC - docs/CHARTER.MD (GitHub)	Governance structure; top management designation (Charter Sec 2.a, 2.g.vi); voting and quorum rules (Sec. 3.b–3.c)
EV-002	TSC Membership List	sigstore/community - MAINTAINERS.md / TSC repository	Identification of top management collective body and individual TSC members
EV-003	Unified SECURITY.md Policy	sigstore/community - SECURITY.md (GitHub)	Vulnerability disclosure process; 24-hr SLA; SRC composition; private advisory workflow; CVE assignment procedure
EV-004	Root-Signing Repository	sigstore/root-signing - GitHub (README, ceremony logs)	TUF root trust model; offline keyholder threshold requirements; public ceremony witnessing records
EV-005	OpenSSF Best Practices Badge	bestpractices.coreinfrastructure.org - Sigstore project entry	Security process self-assessment; badge compliance level; identified gaps
EV-006	GitHub Actions Workflows	.github/workflows/ - cosign, rekor, fulcio repositories	CI/CD pipeline security controls; signing automation; release workflows; test execution
EV-007	Sigstore Architecture Documentation	sigstore/architecture-docs - GitHub	System architecture; component interaction model; scope boundary evidence; trust model description
EV-008	Sigstore Public Good Infrastructure - GCP Hosting Confirmation	OpenSSF Blog - "Running Sigstore as a Managed Service: A Tour of Sigstore's Public Good Instance," October 3, 2023 - openssf.org/blog/2023/10/03/	Confirms Google Cloud Platform as hosting provider for live production infrastructure; establishes cloud dependency risk for A.5.23 and A.8.14 assessment; GCP shared responsibility model evidence
EV-009	GitHub Security Advisories	github.com/sigstore/[repo]/security/advisories	Evidence of SRC process operation - closed advisories; response timelines vs. SLA;

Evidence ID	Artifact Name	Source / Location	Relevance to Audit
			CVE assignments
EV-010	CODEOWNERS Files	CODEOWNERS - cosign, rekor, fulcio repositories	Access control implementation; segregation of duties; mandatory reviewer assignments for sensitive paths
EV-011	CONTRIBUTING.md	sigstore/community - CONTRIBUTING.md	Contributor onboarding; maintainer appointment and removal criteria; decision-making procedures
EV-012	OpenSSF Scorecard Results	scorecard.dev - Sigstore repositories	Automated supply-chain security scoring; dependency vulnerability assessment; branch protection verification
EV-013	Sigstore Infrastructure Post-Mortems	status.sigstore.dev - historical incident records and post-mortem documentation	Evidence of incident response effectiveness (A.5.27); confirms absence of formal DR plan (A.5.30); GCP read replica scaling resolution details; evidence base for NCR-004
EV-014	Trail of Bits 2022 Sigstore Security Audit	Publicly available - search "Trail of Bits Sigstore audit 2022" at trailofbits.com or the Sigstore GitHub for the exact URL	Independent third-party cryptographic design and implementation review (A.5.35); most recent publicly disclosed external audit of the ecosystem; evidence base for OFI-003
EV-015	Google OSS-Fuzz Integrated Projects List	github.com/google/oss-fuzz/tree/main/projects/sigstore	Confirms Sigstore's active integration into the OSS-Fuzz continuous fuzzing programme; primary implementation evidence for A.8.29; supports RR-002 treatment verification